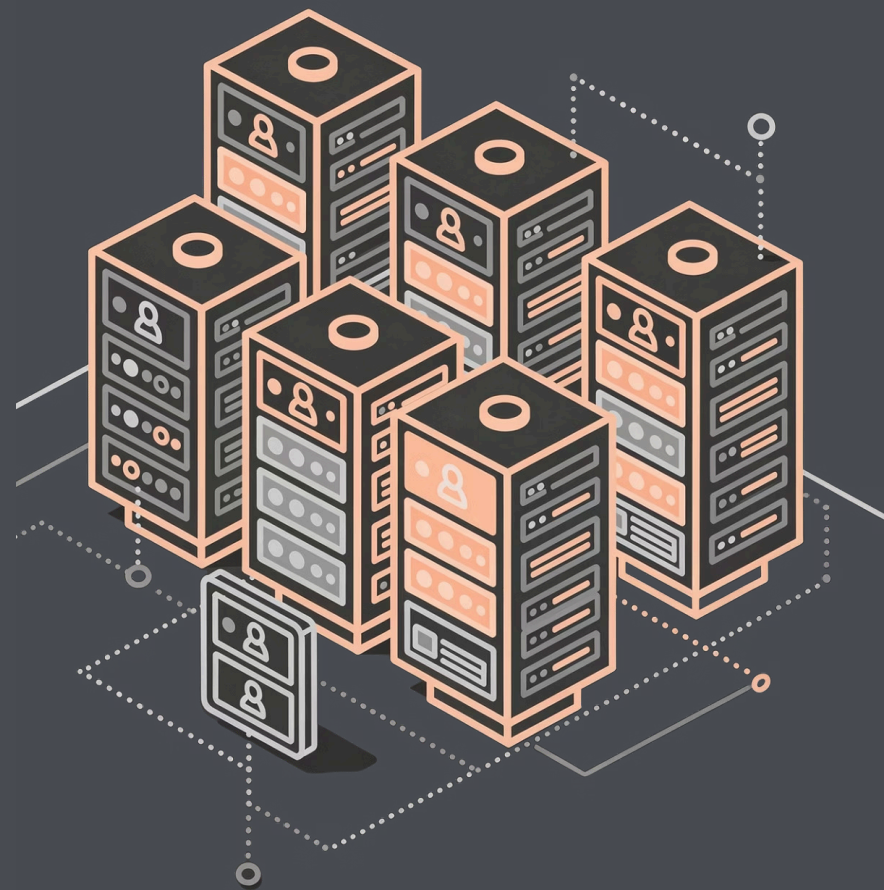




데이터베이스 보안 소개

ACID, BASE 및 CIA 규정 준수

4장

ACID vs BASE: 두 가지 데이터베이스 원칙

현대 데이터베이스는 테이블, 관계형 데이터, XML, JSON 등 다양한 형태를 포함합니다. 관계형 DB는 **ACID** 원칙을, NoSQL DB는 **BASE** 원칙을 따릅니다.

ACID (관계형 DB)	BASE (NoSQL DB)
원자성(Atomicity): 전부 아니면 전무 – 부분 트랜잭션 없음	기본 가용성(Basically Available): 클러스터 노드 전체에 데이터 분산
일관성(Consistency): 트랜잭션 전후 일관된 상태 유지	소프트 상태(Soft State): 즉각적 일관성 부족, 개발자 책임
격리성(Isolation): 각 트랜잭션 독립적 작동	최종 일관성(Eventually Consistent): 시간이 지나면 일관성 확보
내구성(Durability): 커밋된 트랜잭션은 영구 저장	즉각적 일관성 불보장 – 지연된 일관성 허용 시 사용 권장

CIA 3원칙과 데이터베이스 보안

ACID 또는 BASE 데이터베이스 모두 **CIA 보안 3원칙**을 준수해야 합니다. 메타(Meta)의 경우 매일 25억 건의 콘텐츠 업로드, 3억 장의 사진 게시, 하루 4페타바이트 이상의 데이터가 처리됩니다.

기밀성 (Confidentiality)

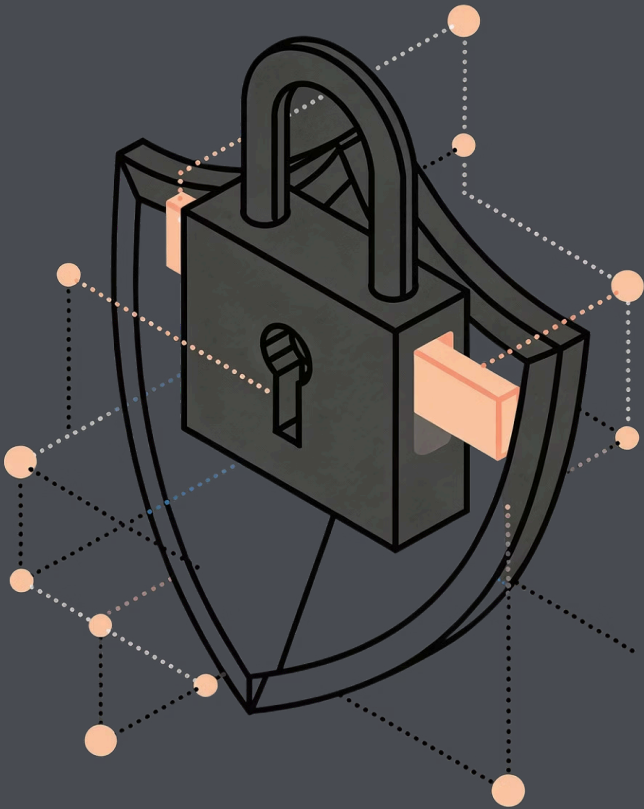
"알 필요가 있는" 사용자에게만 접근 권한 부여. 배경 조사 및 서명된 접근 양식 필수.

무결성 (Integrity)

데이터가 무단으로 변경되지 않도록 보호. 원자성과 일관성이 무결성 유지에 기여.

가용성 (Availability)

권한 있는 사용자가 필요할 때 데이터에 접근 가능. 내구성과 백업이 가용성을 보장.



전송 중 데이터 vs 저장 데이터

저장 데이터 (Data at Rest)

디스크, 테이프, USB, 서버 하드디스크에 저장. 세 가지 백업 방식:

- **전체 백업:** 모든 데이터 복원 가능, 용량 문제 발생
- **차등 백업:** 마지막 전체 백업 이후 데이터 – 복원 시 전체+차등 2개 필요
- **증분 백업:** 일별/주별 증분 저장 – 복원 시 전체+모든 증분 필요

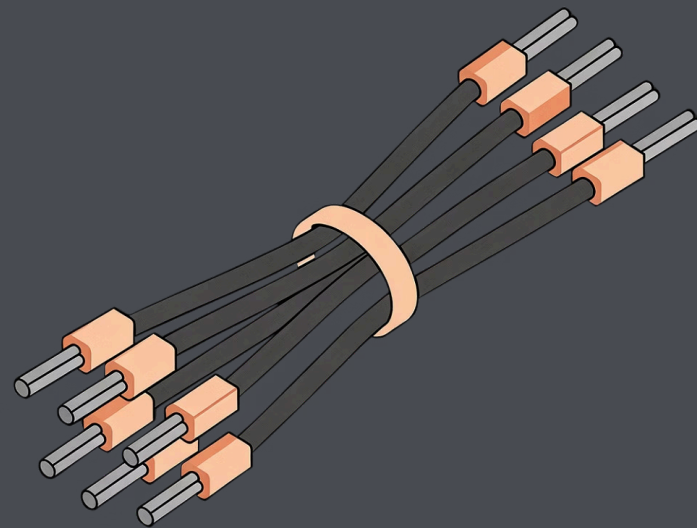
AES256 등 암호화 알고리즘으로 백업 데이터 보호 필수.

전송 중 데이터 (Data in Transit)

이메일, 네트워크 트래픽 등을 통해 이동. 보호 프로토콜:

- HTTPS, SSL, TLS, IPSec 사용
- 방화벽 및 접근 규칙 목록 유지
- 모든 데이터 전송 시 암호화 의무화
- **핵심 원칙: 제로 트러스트(Zero Trust)**

클라우드 저장 시 제공업체에만 의존하지 말고 별도 사본 확보 필수.



데이터 보호 핵심 정책 12가지

01

데이터/자산 분류 규칙 수립 및 정책 엄격 시행

시행되지 않는 정책은 정책이 없는 것과 같습니다.

03

정기 백업 및 데이터 암호화

디스크와 DB에 저장된 데이터를 암호화하고, 암호화 키는 비밀로 유지.

02

이메일 암호화 의무화 및 IAAA 규칙 구현

신원 관리와 인증을 위한 적절한 접근 제어 필수.

04

정기 감사 및 직원 교육

운영을 정기적으로 감사하고, 제로 트러스트 원칙을 모든 기밀 데이터에 적용.

DDL과 DML: 데이터베이스 언어

DDL(데이터 정의 언어)은 테이블·뷰·구조체 등 DB 객체를 생성하고, **DML(데이터 조작 언어)**은 객체 내부 데이터를 변경합니다.

DDL	DML
테이블, 뷰, 객체 생성 명령어	데이터베이스 객체 내 데이터 변경
WHERE, HAVING, GROUP BY 절 없음	WHERE, HAVING, GROUP BY, IN 등 모든 절 사용
기본 키·외래 키 정의 가능	실행 전 테이블 간 관계 이해 필수
자동 커밋 (별도 COMMIT 불필요)	변경 적용 위해 COMMIT 명령 필요
주요 명령: CREATE, ALTER, DROP, TRUNCATE	주요 명령: SELECT, INSERT, UPDATE, DELETE, JOIN

❗ DDL은 DB 구조(열/속성)를 정의하고, DML은 데이터(행/튜플)를 조작합니다. 보안상 일반 사용자에게는 DML 권한만 최소한으로 부여해야 합니다.



안전한 데이터베이스 설계



DB·앱 서버 분리

독립 서버에 DB 설치 시 보안 강화 및 바이러스 전파 차단. 애플리케이션 공격이 DB로 자동 전파되지 않음.



물리적 보안

잠금장치 서버실, 냉난방 시스템, 24/7 가동률 유지. 전자기기 반입 금지, 권한자만 출입 허용.



포트 관리 및 모니터링

기본 포트 비활성화, 미사용 포트 차단. SQL 스크립트로 로그인 시도·계정 잠금 등 실시간 이벤트 모니터링.



IP 화이트리스트 및 패치

허용 IP 목록 관리로 알려진 사용자만 접근 허용. Oracle·SQL Server 등 분기별 패치 즉시 적용.

구조적·기능적 보안

구조적 보안

스키마·테이블·뷰·프로시저로 DB 구성. 기본 키(단일 또는 복합)로 데이터 고유성 유지. PII 대신 **대리 키(Surrogate Key)** 사용 권장.

- 저장 프로시저로 직접 SQL 작성 위험 차단
- 역할(Role) 기반 권한 부여 — 필요한 객체에만 최소 권한
- 읽기 전용 사용자에게는 뷰(View) 제공
- 모든 변경은 변경 관리팀 승인 후 개발 DB 검증 → 운영 배포

기능적 보안

시스템이 "해야 할 일"을 정의하는 보안. 관리 기능, 백업, 감사 추적, 인증 프로세스가 포함됩니다.

- 계정 생성·업데이트 및 최소 권한 설정
- 이중·다중 인증(MFA) 구현
- N회(3~5회) 로그인 실패 시 계정 차단 및 SA 알림
- 직무 분리: 프로그래머는 코드 테스트 불가, 테스터는 코드 작성 불가
- 사용자 활동 일일 모니터링

데이터 보안: 위협과 대응

주요 데이터 유출 원인

- 누출·유출·우발적 노출
- 피싱·스피어피싱 등 사회공학적 공격
- 불만 직원의 내부 공격
- 백도어 조작 및 물리적 절도
- DoS/DDoS 공격, 암호화 키 분실

⚠ 데이터 손실은 PCI-DSS, HIPAA, GDPR, SOX 등 규정 위반으로 이어져 법적 분쟁과 고객 이탈을 초래합니다.

데이터 보호 방법

암호화

해싱, 솔팅, 대칭·비대칭 키 암호화 사용

데이터 마스킹

대리 키, 읽기 전용 뷰, 스�크램블링·치환 기법

접근 제어

역할·권한 부여, 물리적 출입 카드 통제, 직무 분리

정기 백업

전체·증분·차등 백업 병행, 소수 인원만 접근 허용

요약: 데이터베이스 보안의 핵심

ACID & BASE

관계형 DB는 ACID, NoSQL은 BASE 원칙. 두 유형 모두 CIA 보안 3원칙 준수 필수.

데이터 상태

저장·전송·사용 중 세 가지 상태. 전체·증분·차등 백업으로 저장 데이터 보호. HTTPS/TLS로 전송 데이터 보호.

DDL & DML

DDL은 DB 구조 생성(CREATE/ALTER/DROP), DML은 데이터 조작(SELECT/INSERT/UPDATE/DELETE).

4대 보안 영역

구조적·기능적·데이터·절차적 보안. 서버 분리, 역할 기반 접근 제어, 제로 트러스트 원칙이 핵심.

📌 보안은 조직 구성원 모두의 책임입니다. 시행되지 않는 정책은 정책이 없는 것과 같습니다. 데이터 손실로 인한 소송보다 사전 예방이 훨씬 효율적입니다.

